

Prepared by: Kayla Colletti

Date: January 17, 2026

System Assessed: MedVault MQTT Pipeline (Development Environment)

Part 1: Reconnaissance

Traffic Interception

I ran my pipeline with three terminals (broker, publisher, subscriber), then opened a fourth terminal and ran:

```
Shell  
mosquitto_sub -t "#" -v
```

Results after 30 seconds of capture:

- **Messages captured:** 66 messages
- **Topics observed:**

From the MQTT logs (top-right window), the main topics being used are:

- randmarina/sensors/main-building/readings
- auto-<random-ID> (these look like automatically generated IDs for clients or routing)

There's also a topic included inside the payloads:

- hydroficient/grandmarina/sensors/main-building/readings

- **Information visible in each message:**

Device info

- device_id (e.g., GM-HYDROLOGIC-01)

Location

- main-building

Timestamp

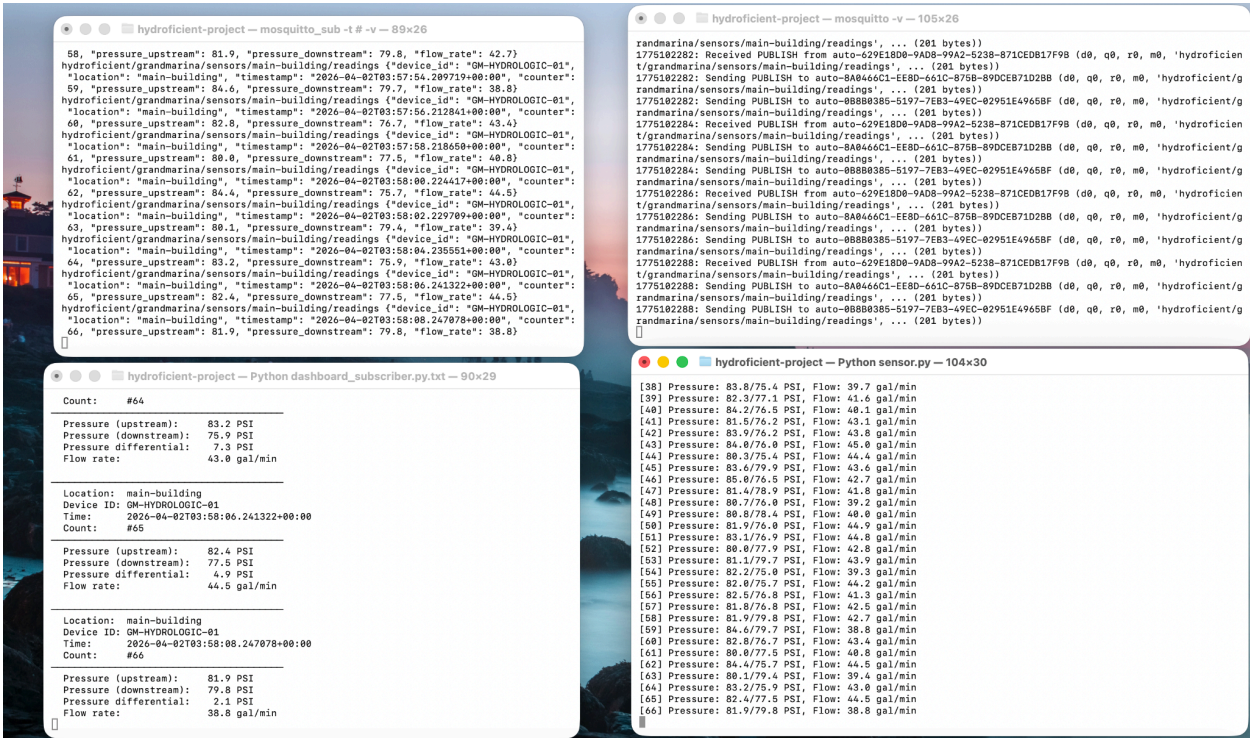
- ISO format (e.g., 2026-04-02T03:58:08...)

Sensor readings

- pressure_upstream (PSI)
- pressure_downstream (PSI)
- pressure differential (calculated in subscriber view)
- flow_rate (gal/min)

Message metadata

- count (message number / sequence)



Part 2: Vulnerability Analysis

Vulnerability	What's the Risk?	Evidence from Your Pipeline	Potential Attack
No encryption	Data is being sent as plain text, so anyone	The MQTT messages in the	An attacker on the same network

	on the network could see the sensor readings as they're transmitted. Which means all sensitive systems data isn't protected.	terminal are fully readable, such as pressures , flow rate, device ID, with no sign of encryption	could sniff the traffic and monitor real-time system data, which could help them plan further attacks.
No authentication	There's nothing that verifies who is sending or receiving messages, so any device could connect and act like a legitimate one.	The publisher and subscriber connect and send messages without the need of a login, username or password.	An attacker could connect to the broker and start publishing fake sensor data pretending to be the real device.
No authorization	Even if a device connects, there are no restrictions on what can and cannot access it, so it can read or write to anything.	Messages are being published and received on topics freely, with no restrictions or access controls visible.	An attacker could subscribe to all sensor topics and collect any data, or even publish malicious data to disrupt the system.
No message verification	There is no way of confirming that messages have not been	Messages are accepted and displayed	An attacker could intercept a message,

	changed during transmission.	immediately with no checks such as signatures, hashes or even validation.	change the pressure or flow values, and send it along, causing incorrect or harmful data to be processed.
--	------------------------------	---	---

Part 3: Remediation Recommendations

1. What defenses would I add?

1. Add encryption so the data isn't sent in plain text
2. Require authentication (username/ password) so random devices cannot just connect
3. Set up authorization standards so devices can only access specific topics
4. Add message verification such as hashes or signatures to ensure data isn't tampered with

2. What's most urgent to fix?

Priority Ranking:

1. Authentication: this is the biggest issue since anyone can connect and pretend to be a real device
2. Encryption: data is completely visible right now
3. Authorization: filter who gets access to what
4. Message verification

3. What trade-offs might these defenses have?

1. Performance: encryption might slow things down a bit and use more system resources
2. Complexity: adds more setup and management (logins, permissions, configs)
3. Cost: could require extra services
4. Compatibility: older devices might not support encryption or any other advanced security feature